

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

Pawn Storm's Dual Zero-Day Exploit Unleashed

Date of Publication

April 10, 2026

Admiralty Code

A1

TA Number

TA2026095

Summary

First Seen: September 2025

Targeted Regions: Turkey, Central and Eastern Europe

Targeted Platforms: Windows

Targeted Products: Microsoft Office, Microsoft Windows (MSHTML Framework)

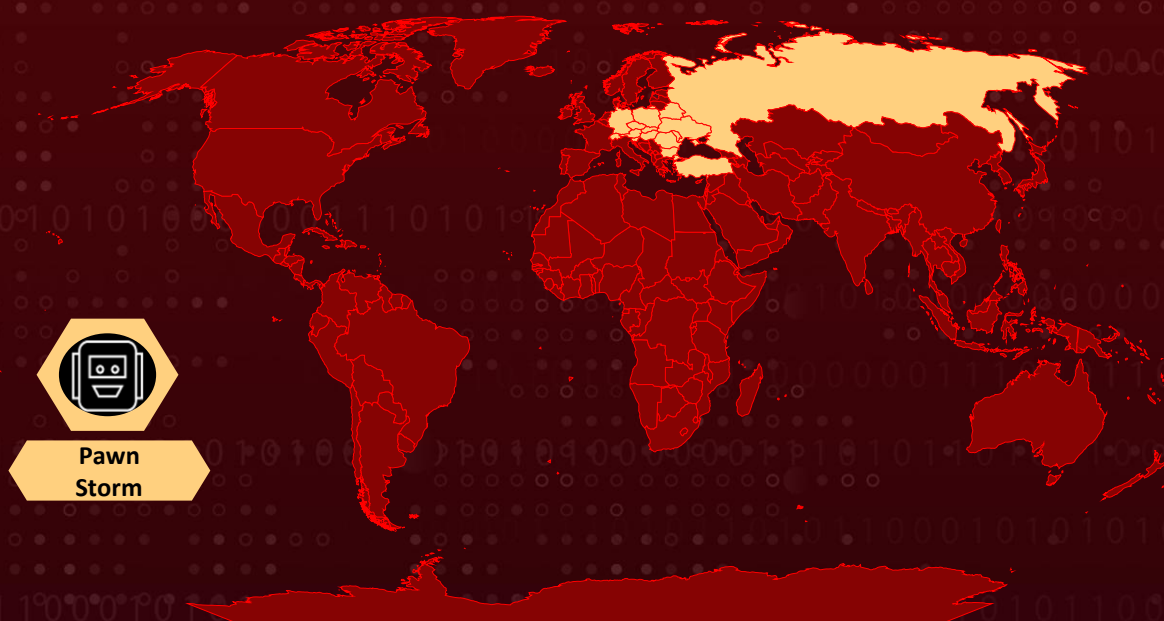
Targeted Industries: Government, Military, Critical Infrastructure, Defense, Emergency Services, Hydrometeorology, Rail Logistics, Maritime and Transport, Humanitarian Aid Organizations

Threat Actor: Pawn Storm (aka APT28, Sofacy, Fancy Bear, Sednit, Group 74, TG-4127, Tsar Team, Strontium, Swallowtail, SIG40, Snakemackerel, Iron Twilight, ATK 5, T-APT-12, ITG05, TAG-0700, UAC-0028, FROZENLAKE, Grey-Cloud, Forest Blizzard, GruesomeLarch, BlueDelta, TA422, Fighting Ursa, Blue Athena, UAC-0063, TAG-110)

Malware: PrismexDrop, PrismexLoader, PrismexStager, PrismexSheet

Attack: Pawn Storm's latest campaign turns a single click into a full-scale compromise, chaining two zero-day vulnerabilities to quietly breach high-value Ukrainian and NATO-linked targets. Disguised as urgent, context-aware emails, the attack lures victims into opening weaponized documents that bypass Microsoft Office protections, trigger hidden WebDAV connections, and execute malicious payloads without raising alarms. What follows is a stealthy, fileless intrusion powered by advanced loaders, custom steganography, and encrypted cloud-based command-and-control, allowing attackers to operate deep within systems undetected. More than just espionage, the operation carries a destructive edge, capable of wiping data entirely, highlighting a calculated blend of precision targeting, technical sophistication, and dual-purpose intent.

🔪 Attack Regions



Targeted

Non-Targeted

© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, Open Places, OpenStreetMap, Overture Maps Foundation, TomTom, Zenrin

Powered by Bing



THREAT ADVISORY • ATTACK REPORT (Red)

2

Hive Pro

CVE	NAME	AFFECTED PRODUCT	ZERO-DAY	CISA KEY	PATCH
CVE-2026-21513	Microsoft MSHTML Framework Protection Mechanism Failure Vulnerability	Microsoft Windows			
CVE-2026-21509	Microsoft Office Security Feature Bypass Vulnerability	Microsoft Office			

Attack Details

#1

It begins with a deceptively routine email, but behind it lies a carefully engineered intrusion chain. Pawn Storm sets the stage with targeted spear-phishing campaigns aimed at Ukrainian government bodies, defense units, meteorological agencies, and NATO-linked logistics networks. The lures are contextually sharp, ranging from hydro-meteorological alerts to military training invites and even weapon smuggling warnings. At the center is a malicious RTF attachment embedding a crafted OLE object that exploits CVE-2026-21509. By abusing a flaw in Microsoft Office’s OLE allowlist, the document silently instantiates the Shell.Explorer.1 COM object, triggering an outbound connection to an attacker-controlled WebDAV server and executing a remote .lnk file, effectively sidestepping Protected View and user prompts.

#2

Once triggered, the attack escalates through a second vulnerability, CVE-2026-21513, in the MSHTML framework. The .lnk file delivers an embedded HTML payload that manipulates browser trust boundaries using nested iframes and multiple DOM contexts. By exploiting weak URL validation within ieframe.dll, the chain forces execution via ShellExecuteExW, bypassing browser security constraints. The use of a shared command-and-control domain across both exploits strongly indicates a coordinated two-stage attack. From here, victims are funneled into one of two payload tracks: the PRISMEX suite or the MiniDoor infection chain.

#3

In the PRISMEX pathway, the intrusion often begins with PrismexSheet, an obfuscated Excel-based dropper that conceals payloads within its own binary using steganographic techniques. Victims are distracted with decoy files themed around Ukrainian military drone inventories and supplier pricing. Persistence is achieved through COM hijacking, modifying registry entries to load a malicious DLL. An alternate loader, PrismexDrop, decrypts embedded payloads using rolling XOR routines, plants them in system directories, and establishes persistence via scheduled tasks and additional COM hijacking mechanisms tied to system processes like explorer.exe.

#4

The operation becomes more sophisticated with PrismexLoader, which masquerades as a legitimate Windows DLL while covertly executing malicious code. Its standout feature is a custom “Bit Plane Round Robin” steganography method that reconstructs payloads from PNG images by distributing data across multiple layers of the file, a technique rarely seen outside Pawn Storm’s tooling. The loader then initializes the .NET runtime directly within memory, using reflective loading to execute the payload without ever writing it to disk, significantly reducing forensic visibility.

#5

The final stage deploys PrismexStager, a Covenant-based implant that leverages encrypted cloud storage services for command-and-control. By distributing its infrastructure across multiple domains, it ensures resilience and stealth in communications. In at least one observed case, the campaign went beyond espionage, issuing destructive commands that wiped user data entirely. This dual-use capability underscores Pawn Storm’s intent: not just to infiltrate and observe, but to disrupt and damage when required.

#6

It is also important to note that elements of this campaign were earlier tracked under the name [Operation Neusplloit](#). Notably, APT28’s adoption of the [COVENANT](#) open-source command-and-control framework is not new; its use in their operations was first observed and documented back in 2024, reinforcing the continuity and evolution of their tooling.

Recommendations



Patch CVE-2026-21509 and CVE-2026-21513 Immediately: Prioritize remediation of both vulnerabilities across the entire fleet. Ensure Microsoft Office and Windows are updated to the latest builds. Both CVEs are listed in CISA's Known Exploited Vulnerabilities catalog with mandatory remediation deadlines.



Restrict Non-Essential Cloud Storage Services: Review and restrict access to non-business-essential cloud storage platforms at perimeter firewalls and web proxies. Maintain an allowlist of approved services and specifically monitor or block File.io traffic unless required for operations, as the PRISMEX campaign abuses this service for C2 communications.



Enforce Macro Execution Policies: Block macro execution for Office files originating from the Internet (Mark of the Web). Apply Group Policy settings to disable VBA macros in documents downloaded or received via email to prevent PrismexSheet execution.



Implement Strict RTF Attachment Filtering: Configure email gateways to block or quarantine RTF attachments, which serve as the primary delivery mechanism in this campaign. Enable enhanced logging for Outlook VBA macro execution and audit VBA projects for unauthorized modifications.



Monitor CLR Initialization in Non-.NET Processes: Deploy detection rules for unusual CLR initialization patterns in native processes, particularly explorer.exe loading clr.dll or mscorlib.dll. Enable the Microsoft-Windows-DotNETRuntime ETW provider to detect in-memory assembly loads from byte arrays rather than file paths.



Enhance Steganography Detection Capabilities: Deploy solutions capable of analyzing image files for anomalous entropy patterns. PrismexLoader's "Bit Plane Round Robin" technique distributes payloads across entire PNG images, which can be detected through statistical analysis of image data distributions.



Potential MITRE ATT&CK TTPs

Tactic	Technique	Sub-technique
Initial Access	T1566 : Phishing	T1566.001 : Spearphishing Attachment
Execution	T1059 : Command and Scripting Interpreter	T1059.005 : Visual Basic
		T1059.001 : PowerShell
	T1204 : User Execution	T1204.001 : Malicious Link
Persistence	T1546 : Event Triggered Execution	T1546.015 : Component Object Model Hijacking
	T1053 : Scheduled Task/Job	T1053.005 : Scheduled Task
Defense Evasion	T1574 : Hijack Execution Flow	T1574.002 : DLL Side-Loading
	T1027 : Obfuscated Files or Information	T1027.003 : Steganography
	T1055 : Process Injection	
	T1553 : Subvert Trust Controls	T1553.005 : Mark-of-the-Web Bypass
Collection	T1114 : Email Collection	T1114.001 : Local Email Collection
Command and Control	T1071 : Application Layer Protocol	T1071.001 : Web Protocols
	T1102 : Web Service	
Exfiltration	T1048 : Exfiltration Over Alternative Protocol	T1048.003 : Exfiltration Over Unencrypted/Obfuscated Non-C2 Protocol



✂ Indicators of Compromise (IOCs)

TYPE	VALUE
SHA256	5a88a15a1d764e635462f78a0cd958b17e6d22c716740febc114a408eef66705, cbea5c7d71a5a6cb9153b00d2d27e6a3579004c27f5e817f317eeebdc e7f805f, c87be2f30cc974d0859526b9dd104e015f0e5d04bc43198305537f276 705691e, 57357655a62e3a8b1f4b78e1d3ed7e0f6d59a9bac213087294f91bb78 47b2a8f, 92a56faf6eccfad8281213393fad584cbd7b9e04db875dfb8fc01e1dbf4 cbdd1, de2b24d08e795ad9cdd1b74882a3626febefadafaf8ff0ae76cba16dcaa 0f8bc, 71ef7438d785f3102735ed9d9233ac366507c82fc4fac4de88f687a105 c84df6, dbf33417e40f0fe8078a11d81f7d323bfed1912f5cb62d765c1be72561 474659, ffca9d56feb5ec8844b42f513cecd67a554a2ddb3408dbc6942e2fd604 53aee1, 4f6aa45f2ead7ddb6a81f4a2b9745f8ec117d96971d4d80bb06f3ec3db 5951da, a848d48c79b77753a876d876baa3e802a5a37be37e7a772ddbd9a266 cd1796ac, 36f5e04213d446c4208864f32a6af18d5184bbbb628808ef0a876ea6c 31ea0b3, e3f9519a21a16ff2c8f989034e47fbc91a2d019e09a1d7d17ff751e52a0 9d15b, 8f4bca3c62268fff0458322d111a511e0bcfba255d5ab78c45973bd293 379901, bb309ed228f97f3cf864ea89fa502f43214af4fb4b98d78837e42c4a49 40b5f9, 970e68e8b68e0c5f3f18cd55e0c82304e81547f8ebf349390db1c8a06 81699fa, 92697d518e72a30800e96b63cf875573bd536c9b993d22014238f6a9f 0e19e0f, 144bddb48890fa680dfd226e36c0ef2c6d6f98a365aea48399edd0d03 88711a1

TYPE	VALUE
SHA256	9aa8b46d62eb426842b8ff0fc28e64719494f0f64d516253caa71a6fd86e9ad3, 0bb0d54033767f081cae775e3cf9ede7ae6bea75f35fbfb748ccba9325e28e5e, 2822c72a59b58c00fc088aa551cdeeb92ca10fd23e23745610ff207f53118db9, 3f446d316efe2514efd70c975d0c87e12357db9fca54a25834d60b28192c6a69, 40c2e559992a7f595c593b419930a3f216516c3042ad86fb985348d53b6e01b9, 52b6fb40e7efb09c2bebe8550178e7e30009600bdedd1acae085d753761b7598, 5c2a2c49e200a2d048f477440da75ff4a99c676943f6f7cac1ce70190520f998, 7ccf7e8050c66eed69f35159042d8043032f8afe48ae1f51fce75ce2c51395f2, 8b0ab7f7f48bf847c3af570da7dd3e26eda9e4c4ab38e5f97a7cd09b8ace943a9, 8c1dc9732884c6078b23953b78314a8d0d8b8d9fe42e5f97a7cd09b8ace943a9, 968756e62052f9af80934b599994addbab29f8dc2615c47cda512bae48771019, 9f4672c1374034ac4556264f0d4bf96ee242c0b5a9edaa4715b5e61fe8d55cc8, a876f648991711e44a8dcf888a271880c6c930e5138f284cd6ca6128eca56ba1, b7342b03d7642c894ebad639b9b53fd851d7958298f454283c18748051946585, baad1153e58c86aa1dc9346cdd06be53b5dd2a6cf76202536d6721c934008f8e, c4389cc34b672c4f885547f413bf38575e6ee2b23a0ddfd306a69c1775db6fc, d213b5079462e737eb940ac46c59e386eb6ca7f8decc95a594b3d8f3b6940010, e792adf4dff54faca5b9f5b32c1a2df3a6a955e722f1be8df2451c03ed940e41, ff310202cbff28b47f03b4b0129a5b925a4b7b065af002072a3796920720c34e

TYPE	VALUE
SHA256	aefd15e3c395edd16ede7685c6e97ca0350a702ee7c8585274b45716 6e86b1fa, a1b86c8957f460b78d906e1bdede829c4f3b5500d6449e8eba3ae5c30 2be2b86, 64f2d135603220b47dd430be5e059dcedd80ad2bc3c17500816ec5d0 7e39d3d1, 8d09eb897f2bc98035ef88152e2b5d571a7b61878dd12b451e043708 9487a417, 0148c79cdfb21d87731f8e45d38c27242863ec4ea9621c59e537f59ed 501c119, 0366b9bc02b00fda8ea28929b7159a038a43da0aa0299b8279bffc2d7 e73892a, 0ab301b3e43ac2394ec25c5d1caf79aa0785a2eaca801b0b1b6d4621f 5e8c736, 948f109756cba0b01f11fd3db9c47a76125c4b1d9467ff1bd9c5013d21 4c933f, 0db5bd9cb832618c60e0f3c0dfad719403473b85a82253dc0f6a83918 00c0d0b, ce2c475461d57f222a6aa22f49420f804a43c2eb29abf8553457a7d30f 7cb024, a95ee15e8ccf84521df2c80b1525fd89e205fc0280c3f6cbc24751080e a29206, 003cd35535ab9350a407a7dcd016c305fb8dbac03d41d5b7d3917c80 4b66dd2a, ba01a2355414dfedda9ac5ce0d7a2d8edfb89ec3ae3e68fc81db035caa 741854, ea4679d1c05bef0c38b4d910a87f79070ca2e661779a255f523d57ef1 921a1c7, 1565934e529b5a9b6af7e60800a91f7ac3a6ec2e24b4f6df0f808d253b 45cf42, 3b411e9f282ba97feb56cb5a8bf3e9a1d1e9a5f8406e72213dfb140166 a54012, eb187ff574ab25dffa12dd05ff5f9716f4fc489e2de457c4a50aa0d3cb0f 1479, 9dad95985eea3b299c387e663a6edfbbf057cc634f2ca99c410238480 bcd4e17, eec4122a1262579806888d8a6a215b333d5e4eec600b5caba91e187b 7b468e22

TYPE	VALUE
SHA256	8858ee314c4db60a3f097ede38cbe64ce4e4b1e67041bad1e0580953011dfec1, 15b99e8b30ce0b57fe030243aa795b74b0d7dcd773f28f677f629f132bce1ff8, 8438a4cd675c81cefd6a8d96b9e48b2730cc9086b4c531883f966a8818cccbef, 1d27a5ca6703f6e757d30adc8d4d703c2e99316d1eaaaf5c68635c47e8e0396e, d6b75d496e28692dd02c6336ac5c5a42ac88da7ad315d3e508963cf8d46926b3, 84464879c2ced71ff6a30277252af70a20e18c563b8e45f4a92e004f41fe3e01, be859b4f4576ec09b69a2ef2d119939f7eb31de121aa01d38e1f0b2290f5a15e, 969d2776df0674a1cca0f74c2fccbc43802b4f2b62ecccecc26ed538e9565eae, f7bda19543074c788c321aed42d955b4d50b7b0a2c3ca83b7f45b5e8b9a10491, 18f9c08e60bb88891f5bb5dd133ae804703c0797bebdde397c01513a67b86a1e, 5f397327aeb20718e364bef61e8bad507772708a7d1bf55d8b845170c69f3de0, 3cb09154a839a5de6e8ef4a04a933b7362afb56cdc4e91368b237e9bc b1cd7b9, 1ed863a32372160b3a25549aad25d48d5352d9b4f58d4339408c4eea69807f50, d944abab1481457eacf9f1d08f835980c2146ec91513e2eb94714c6ab aec5f34, 5a17cfaea0cc3a82242fdd11b53140c0b56256d769b07c33757d61e0a0a6ec02, b2ba51b4491da8604ff9410d6e004971e3cd9a321390d0258e294ac42010b546, c91183175ce77360006f964841eb4048cf37cb82103f2573e262927be4c7607f, fd3f13db41cd5b442fa26ba8bc0e9703ed243b3516374e3ef89be71cbf07436b, e8889528e2114a700438f73da09449cfdde655a29da6794d0449b5e8aa4dbf2a

TYPE	VALUE
SHA256	f0d443055143cbd6bce8ef96b52d430e2db321b37b8b93a2a9d0354651702790, 14acfac5fc59d5ee9592399e51636ec47fbea36623555635a1361fcd2f50dfa, bbfd93dbf43236b7f64017ad20f72dd611de1acb4b15e02569e42887467b34d4
Email Address	dubravka[.]jovanovic2024[@]proton[.]me, a[.]matti444[@]proton[.]me, TeoAbarquero[@]tutamail[.]com, UffeTroelsen[@]atomicmail[.]io
Domains	wellnesscaremed[.]com, wellnessmedcare[.]org, freefoodaid[.]com, longsauce[.]com, filen[.]io, dbca10b5-63e0-42ec-ad10-de13be96dc42[.]dnshook[.]site, %username%dbca10b5-63e0-42ec-ad10-de13be96dc42[.]dnshook[.]site, %username%[.]910cf351-a05d-4f67-ab8e-6f62cfa8e26d[.]dnshook[.]site
Network URLs	hxxp[:]//webhook[.]site/910cf351-a05d-4f67-ab8e-6f62cfa8e26d?\$env[:]=USERNAME, hxxps[:]//3008[.]filemail[.]com/api/file/get?filekey=6ir3NT7t9kNXSp3-IGKKYKDgHqEgyNaul3V4UhsSHWFdjK8qOr8rzQJ63avm4g, hxxps[:]//gateway[.]filen[.]io, hxxps[:]//gateway[.]filen[.]net, hxxps[:]//gateway[.]filen-1[.]net, hxxps[:]//gateway[.]filen-2[.]net, hxxps[:]//gateway[.]filen-3[.]net, hxxps[:]//gateway[.]filen-4[.]net, hxxps[:]//gateway[.]filen-5[.]net, hxxps[:]//gateway[.]filen-6[.]net, hxxps[:]//egest[.]filen[.]io, hxxps[:]//egest[.]filen[.]net, hxxps[:]//egest[.]filen-1[.]net, hxxps[:]//egest[.]filen-2[.]net, hxxps[:]//egest[.]filen-3[.]net, hxxps[:]//egest[.]filen-4[.]net, hxxps[:]//egest[.]filen-5[.]net, hxxps[:]//egest[.]filen-6[.]net, hxxps[:]//ingest[.]filen[.]io, hxxps[:]//ingest[.]filen[.]net, hxxps[:]//ingest[.]filen-1[.]net, hxxps[:]//ingest[.]filen-2[.]net, hxxps[:]//ingest[.]filen-3[.]net, hxxps[:]//ingest[.]filen-4[.]net, hxxps[:]//ingest[.]filen-5[.]net, hxxps[:]//ingest[.]filen-6[.]net, \\longsauce[.]com@SSL\DAV\DEfault\data[.]LnK?init=1, \\longsauce[.]com@SSL\davwwwroot\DAV\DEfault\data[.]LnK?init=1, , file[:]//wellnessmedcare[.]org@ssl/cz/Downloads/document[.]LnK?init=1, file[:]//wellnessmedcare[.]org/davwwwroot/cz/Downloads/document[.]LnK?init=1, \\freefoodaid[.]com@SSL\tables\tables[.]LnK?init=1,

TYPE	VALUE
Network URLs	\\freefoodaid[.]com@SSL\davwwwroot\tables\tables[.]Lnk?init=1, file[:]//wellnesscaremed[.]com@ssl/buch/Downloads/document[.]doc[.]Lnk?init=1, file[:]//wellnesscaremed[.]com/buch/Downloads/document[.]doc[.]Lnk?init=1, file[:]//freefoodaid[.]com@80/documents/2_2[.]Lnk?init=1, file[:]//freefoodaid[.]com/davwwwroot/documents/2_2[.]Lnk?init=1, file[:]//wellnesscaremed[.]com@ssl/venezia/Favorites/document[.]doc[.]Lnk?init=1, file[:]//wellnesscaremed[.]com/venezia/Favorites/document[.]doc[.]Lnk?init=1, file[:]//wellnessmedcare[.]org@ssl/pol/Downloads/document[.]Lnk?init=1, file[:]//wellnessmedcare[.]org/davwwwroot/pol/Downloads/document[.]Lnk?init=1
File Path	%appdata%\Microsoft\Office\databackup.ini, %appdata%\Microsoft\Outlook\VbaProject.OTM, %appdata%\Microsoft\Office\VbaProject.OTM, C:\ProgramData\izjava oopterecenjuzaradeprekopolaovjerena-ivan simovic.pdf, %APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\EHygbjYHlw.vbs, %APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\FYfnahVXea.vbs, %APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\1.vbs, %APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\2.vbs, C:\ProgramData\UGOVORCI FEBRUAR.docx, %APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\outlook.vbs, C:\ProgramData\testtemp.ini, %Temp%\Test, %temp%\DEFAULT-786XQ7W-20251022-2145.log, %temp%\DEFAULT-3Q7J61W-20251101-1045.log, %programdata%\USOShared\Logs\User\adwapi64.dll, %programdata%\Microsoft\DeviceSync\8acd6e71-bf10-4800-aeed-7de00edc9781\background.png, %PROGRAMDATA%\USOPublic\Data\User\EhStoreShell.dll, %PROGRAMDATA%\Microsoft OneDrive\setup\Cache\SplashScreen.png, %TEMP%\Diagnostics\office.xml
Filenames	EhStoreShell.dll, SplashScreen.png, SimpleDropper.dll, office.xml

TYPE	VALUE
IPv4	193[.]187[.]148[.]169, 23[.]227[.]202[.]14, 72[.]62[.]185[.]31, 159[.]253[.]120[.]2
Host Registry Key	HKCU\Software\Classes\CLSID\{D9144DCD-E998-4ECA-AB6A-DCD83CCBA16D}



Patch Links

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-21509>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-21513>



References

https://www.trendmicro.com/en_us/research/26/c/pawn-storm-targets-govt-infra.html

<https://hivepro.com/threat-advisory/microsofts-february-2026-patch-tuesday-fixes-active-zero-day-exploits/>

<https://hivepro.com/threat-advisory/cve-2026-21509-microsoft-office-zero-day-under-active-exploitation/>

<https://hivepro.com/threat-advisory/operation-neusplit-apt28-weaponizes-cve-2026-21509>

<https://hivepro.com/threat-advisory/apt28-targets-government-agencies-with-beardshell-and-covenant/>

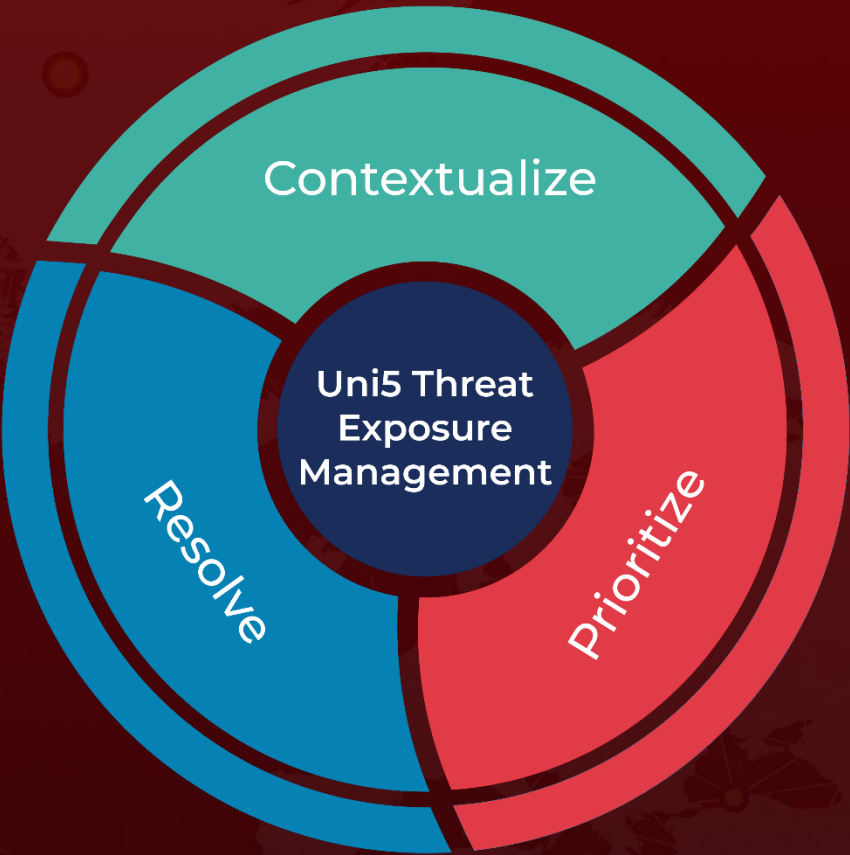
<https://blog.synapticsystems.de/apt28-geofencing-as-a-targeting-signal-cve-2026-21509/>



What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

April 10, 2026 • 12:30 AM

© 2026 All Rights are Reserved by Hive Pro



More at www.hivepro.com